Sicurezza dei Sistemi Informativi

Appello d'Esame del 18 Giugno 2025

Anno Accademico 2024-2025

Politecnico di Torino — Docente: Prof. Cataldo Basile

2025-06-18

1 Testo Ufficiale dell'Esame

Parte 1: Quiz Ufficiale dell'Appello 18/06/2025

Selezionare le affermazioni corrette per ciascuna sezione del quiz Moodle:

1.1 Sicurezza Perimetrale e Monitoraggio:

a. I packet filter sono mediamente più veloci degli application-level filter.

b. Un network-based IDS monitora il traffico delle sottoreti di un'azienda, non può essere usato per identificare attacchi provenienti da Internet.

c. In un'architettura di tipo 'screened subnet' si può mascherare la rete interna ma potrebbero essere necessarie funzionalità di NAT.

d. Gli IDS avanzati, basati su AI, permettono di identificare e reagire alle minacce in maniera più efficace rispetto a quelli tradizionali (basati sulle analisi statistiche).

e. In un SOC dovrebbero esserci esperti di analisi forense, perché il SOC deve includere tutte le figure professionali relative alla sicurezza informatica.

f. Quando un'azienda viene attaccata e vengono "esfiltrati" dei dati, c'è il rischio di violazioni del GDPR.

g. Le regole di un firewall sono un esempio di politica di autorizzazione.

h. Un WAF posto in modalità stealth davanti ad un server è in grado di filtrare anche il traffico di applicazioni web cifrate mediante TLS.

1.2 Crittografia e Algoritmi:

a. A parità di bit delle chiavi, la crittografia a curve ellittiche permette di ottenere un livello di resistenza maggiore rispetto alla crittografia asimmetrica tradizionale (campi modulo n).

b. A parità di dimensione del plaintext, cifrando con AES128-ECB si devono trasferire sempre meno dati rispetto ad AES128-CBC.

c. Gli algoritmi di Hash vengono usati come Pseudo Random Function per generare le chiavi che garantiscono confidenzialità e integrità+autenticazione nel TLS.

d. Se l'ultimo blocco di dati cifrato con DES termina con `0x1324354605050505` (esadecimale) verrà accettato correttamente sia con che senza l'opzione `-no-pad` (OpenSSL).

e. È buona prassi rinnovare spesso le chiavi crittografiche simmetriche se si devono cifrare grosse quantità di dati perché, se non venissero rinnovate, gli attaccanti potrebbero ottenere informazioni statistiche utili ad attaccare la confidenzialità dei dati con esse cifrate.

f. Quando si usano algoritmi asimmetrici, l'operazione matematica svolta per cifrare con la chiave pubblica è la stessa che si usa quando si decifra con la chiave privata (= si usa la stessa formula con gli stessi parametri).

g. L'attacco Heartbleed contro il TLS permette di ottenere la chiave privata del certificato del server TLS.

h. Le key derivation function sono inefficienti, il numero di iterazioni non deve essere aumentato oltre 10000 per evitare di penalizzare le normali procedure di autenticazione.

i. Gli algoritmi di tipo stream sono attaccabili: la loro confidenzialità può essere violata desincronizzando i flussi di dati cifrati un bit alla volta.

1.3 Controllo Accessi e Protocolli di Rete:

a. I server RADIUS non sono in grado di fare da proxy, quelli di DIAMETER invece sì.

b. PPP serve ad incapsulare pacchetti di livello 3 per trasferimenti punto-punto.

c. Il protocollo RADIUS inoltra messaggi EAP senza modificarli.

d. Se si usa 802.1X, gli AP non devono necessariamente gestire l'autenticazione degli utenti.

e. Il protocollo RADIUS incorpora metodi di protezione della confidenzialità dei pacchetti insufficienti.

f. EAP è un 'middleware' che permette di usare diversi tipi di autenticazione con diversi tipi di protocolli di comunicazione di livello 2.

g. Per come è progettato, EAP richiede frequenti cambiamenti allo standard, in pratica ogni volta che è necessario aggiungere un nuovo tipo di autenticazione.

h. In ambito PPP, se usati correttamente, PAP e CHAP sono ancora considerati metodi di autenticazione forti.

i. Eduroam non richiede la federazione delle istituzioni, perché l'autenticazione viene svolta direttamente dal server della propria istituzione.

1.4 Standard di Sicurezza, Sistemi Operativi ed Exploitation:

a. Un Protection Profile definisce le regole di valutazione di una specifica categoria di prodotti, permette quindi a chi richiede una certificazione di concentrarsi su un security target specifico.

b. Un Disassembler può essere usato per analizzare a run-time lo stato dei registri di un binario in esecuzione.

c. La Data Execution Prevention evita che possano essere eseguiti attacchi di buffer overflow che richiedono di eseguire codice dallo Stack.

d. Le tecniche di anti-tampering rendono incomprensibile il codice per evitare che si riesca a modificarlo.

e. L'Information Security Management System (ISMS) permette di valutare quanto bene uno specifico prodotto (TOE) gestisce i dati aziendali.

f. Una certificazione di sicurezza aumenta la nostra fiducia nel prodotto certificato perché sappiamo che un'apposita entità terza ha verificato che determinate proprietà di sicurezza siano effettivamente soddisfatte.

g. Le tecniche di protezione remota sono più efficaci di quelle locali perché non saturano le risorse computazionali delle macchine che eseguono la specifica copia del software da proteggere.

h. Il Trusted Computer System Evaluation Criteria prevede un processo di certificazione moderno, ripetibile, snello e relativamente economico.

i. L'oggetto della valutazione di un processo di certificazione è una precisa combinazione di hardware e software ed è scorretto estendere la valutazione "per analogia" ad altre configurazioni.

1.5 Domanda 5: Mi voglio ritirare da questo appello? (Vero / Falso).

1.6 PKI, Crittografia Avanzata e Firme Digitali:

a. Il traffico scambiato con una ciphersuite `TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256` può essere accelerato solo se un HSM sia SHA256 sia AES128.

b. L'OCSP mi permette di identificare tutte le firme non valide perché riporta il momento in cui il certificato è stato revocato.

c. Il problema matematico alla base dell'algoritmo di firma ECDSA è vulnerabile ad attacchi fatti con computer quantistici.

d. Un certificato digitale di un utente che passi tutte le verifiche crittografiche correttamente, va scartato se il certificato della CA che lo ha emesso è stato revocato perché la chiave (della CA) è stata compromessa prima della sua emissione (del certificato dell'utente).

e. L'algoritmo di Shor renderà attaccabili le firme digitali calcolate con gli algoritmi della crittografia post-quantum.

f. Un certificato X.509 di tipo Diffie-Hellman riporterà tre parametri: il numero primo p, il generatore g e $g^x \bmod p$, dove x è il parametro privato del possessore del certificato.

g. Il contenuto di un documento firmato di tipo PAdES può essere letto solo da lettori di PDF in grado di estrarre e verificare la firma digitale.

h. Un documento contenente una macro (es. Word) può essere firmato, ma i dati che verranno visualizzati non sono necessariamente quelli che sono stati firmati.

i. Dato un documento che deve essere firmato da n firmatari, se si scegliesse di usare firme parallele la verifica richiederebbe in media meno tempo rispetto al caso in cui si scegliesse l'uso di firme sequenziali.

1.7 Meccanismi di Autenticazione Avanzati e Credenziali:

a. I CRA simmetrici sono resistenti allo sniffing.

b. Nel Digital Authentication Model del NIST, il Claimant deve eseguire un protocollo di autenticazione con un Verifier su richiesta di un Relying Party.

c. Zero-Knowledge Password Proof è, nonostante il nome, un esempio di passwordless authentication.

d. Il token FIDO2 è in grado di eseguire una procedura di CRA asimmetrico con un backend FIDO presente sul server.

e. I sistemi biometrici (es. mediante dispositivo personale) se usati come ulteriori fattori di autenticazione rendono l'autenticazione più sicura.

f. L'uso di un OTP è obbligatorio se bisogna implementare la multi-factor authentication.

g. In Kerberos, gli utenti ricevono dal Ticket Granting Server le chiavi simmetriche dei servizi (Ks) che hanno richiesto.

h. Uno dei principali problemi dell'uso di sistemi biometrici è la non sostituibilità delle credenziali compromesse.

i. Un dictionary attack, a parità di tempo a disposizione, ha una maggiore probabilità di identificare le password degli utenti rispetto ad un approccio a forza bruta, considerando che molti scelgono password deboli.

Parte 2: Compito Scritto (Domande Aperte)

Domanda 1: Reverse Engineering Applicato al Software Spiegare cosa è il processo di Reverse Engineering applicato al software. Indicare e classificare i tipi di tool che possono essere usati, i tipi di analisi che permettono (statica, dinamica, simbolica) e gli artefatti che possono essere ottenuti (codice disassemblato, grafi del flusso di controllo CFG, decompilati ad alto livello, sequenze di chiamate a sistema).

Domanda 2: Negoziazione Completa nel TLS Handshake Protocol (v1.2+) Spiegare precisamente tutto quello che viene negoziato durante il TLS Handshake Protocol (con riferimento a TLS 1.2 e relative evoluzioni in TLS 1.3). Indicare, per ognuno degli elementi negoziati:

- Le proprietà di sicurezza garantite e la loro rilevanza;
- Come vengono scambiate o derivate le chiavi crittografiche (DHE/ECDHE, Pre-Master Secret, Master Secret, session keys);
- Quali sono le garanzie fornite dalla Perfect Forward Secrecy (PFS).

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Parte 1: Analisi Puntuale del Quiz Ufficiale

1.1 Sicurezza Perimetrale e Monitoraggio:

- **a.** [**VERA**]: I packet filter (stateless o stateful a L3/L4) analizzano solo gli header IP/TCP/UDP (IP sorgente/destinazione, porte, flag TCP) senza riassemblare lo stream né ispezionare il payload applicativo L7. Operano a livello kernel/ASIC con latenza minima, risultando ordini di grandezza più veloci rispetto agli application-level filter (proxy L7), che devono riassemblare l'intero stream TCP e parsare la semantica applicativa (es. HTTP/HTTPS).
- **b.** [**FALSA**]: Un Network-based IDS (NIDS) può e deve essere impiegato anche per monitorare le interfacce perimetrali e la DMZ esposte verso Internet, intercettando scansioni di porte, tentativi di exploit, attacchi DoS/DDoS e traffico malevolo proveniente dall'esterno prima che penetri nella rete interna.
- **c.** [**VERA**]: In un'architettura a sottorete schermata (screened subnet o DMZ con doppio firewall), la rete interna adotta tipicamente indirizzi privati (RFC 1918) ed è completamente isolata. Per consentire ai client interni l'accesso a Internet senza esporre la topologia interna, è indispensabile implementare funzionalità di NAT/NAPT sul firewall perimetrale.
- **d.** [**FALSA**]: Gli IDS basati su AI/machine learning (anomaly detection) soffrono storicamente di un elevato tasso di falsi positivi dovuti all'intrinseca variabilità del traffico lecito e al fenomeno del *concept drift*. Al contrario, gli IDS tradizionali basati su analisi statistica consolidata o signature deterministiche offrono un comportamento predicibile e un tasso di falsi positivi nettamente inferiore su pattern noti.
- **e.** [**VERA**]: In conformità con i framework NIST SP 800-61 e standard internazionali, un Security Operations Center (SOC) completo include figure specializzate in Digital Forensics and Incident Response (DFIR) per analizzare la catena di custodia, acquisire evidenze digitali e condurre il reversing di malware durante e dopo un attacco informatico.
- **f.** [**VERA**]: L'esfiltrazione non autorizzata di dati personali integra la fattispecie di Data Breach ai sensi dell'Art. 33 del GDPR (Regolamento UE 2016/679), imponendo al titolare del trattamento l'obbligo formale di notifica all'Autorità Garante entro 72 ore e agli interessati se il rischio per i loro diritti è elevato (Art. 34).
- **g.** [**VERA**]: Le regole di un firewall stabiliscono formalmente quali entità (IP/porte sorgente) possono accedere a quali risorse (IP/porte destinazione) secondo quali modalità (protocollo), costituendo a tutti gli effetti un'istanza operativa di una politica di autorizzazione.
- **h.** [**FALSA**]: Un WAF in modalità stealth o bridge L2 puro, pur essendo invisibile a livello di instradamento IP, non possiede le chiavi di sessione TLS né il certificato/chiave privata del server per decifrare il traffico HTTPS crittografato end-to-end. Per ispezionare il payload HTTP protetto da TLS, il WAF deve necessariamente agire da reverse proxy o terminatore TLS (terminando la sessione crittografica).

1.2 Crittografia e Algoritmi:

- **a.** [**VERA**]: La crittografia su curve ellittiche (ECC) si basa sulla complessità computazionale del problema del logaritmo discreto su curve ellittiche (ECDLP), per il quale non sono noti algoritmi sub-esponenziali come il crivello del campo dei numeri (NFS) usato contro RSA. Pertanto, una chiave ECC a 256 bit offre un livello di sicurezza equivalente a una chiave RSA a 3072 bit.
- **b.** [**FALSA**]: La modalità ECB e la modalità CBC operano su blocchi della medesima dimensione (128 bit per AES). Applicando il padding PKCS#7, il ciphertext risultante ha esattamente la medesima lunghezza in entrambe le modalità (multiplo intero di 16 byte), a meno dei 16 byte dell'Initialization Vector (IV) iniziale trasmesso in CBC; non è pertanto vero che con ECB si trasferiscono "sempre meno dati" in termini intrinseci di cifratura del blocco.
- **c.** [**VERA**]: Sia in TLS 1.2 (tramite la Pseudo-Random Function basata su HMAC-SHA256, RFC 5246) sia in TLS 1.3 (tramite HKDF basato su SHA-256/384, RFC 8446), le funzioni di hash crittografico costituiscono il motore matematico delle PRF impiegate per derivare il Master Secret e le relative chiavi simmetriche di cifratura (bulk encryption) e autenticazione.
- **d.** [**VERA**]: DES ha un blocco di 8 byte (64 bit). La sequenza fornita `0x1324354605050505` termina con 4 byte visibili `0x05`, ma se gli ultimi 5 byte sono `0x05` (cioè 3 byte di dati seguiti da 5 byte di padding), secondo lo standard PKCS#7 ciò costituisce un blocco con padding valido di 5 byte. Di conseguenza, OpenSSL decifra e valida correttamente il blocco sia con rimozione del padding standard sia con l'opzione `-no-pad` (che si limita a restituire il blocco grezzo senza effettuare uncheck).
- **e.** [**VERA**]: Cifrare elevati volumi di dati con la medesima chiave espone ad attacchi basati sulle collisioni dei blocchi per il paradosso del compleanno (es. Sweet32 su cifrari a 64 bit dopo 2^{32} blocchi) o a perdite di keystream; il rekeying periodico è una misura indispensabile di igiene crittografica.
- **f.** [**FALSA**]: In crittografia asimmetrica (es. RSA), la cifratura usa l'esponente pubblico e ($c = m^e \bmod n$) mentre la decifratura usa l'esponente privato d ($m = c^d \bmod n$), dove $e \cdot d \equiv 1 \pmod{\phi(n)}$. I parametri matematici impiegati sono distinti e inversi tra loro, non gli stessi.
- **g.** [**FALSA**]: L'attacco Heartbleed (CVE-2014-0160) sfrutta un buffer over-read nell'estensione Heartbeat di OpenSSL per leggere fino a 64 KB di memoria heap arbitraria del server. Sebbene tale memoria possa fortuitamente contenere frammenti di chiavi o password rimaste in memoria, l'attacco non estrae direttamente né determinatamente la chiave privata X.509 del server su richiesta.
- **h.** [**FALSA**]: Le Key Derivation Functions (PBKDF2, bcrypt, Argon2) sono intenzionalmente progettate per essere computazionalmente onerose e lente (slow by design). Aumentare il numero di iterazioni (ben oltre le 10.000, raccomandate oggi centinaia di migliaia secondo NIST SP 800-132) è fondamentale per contrastare attacchi di forza bruta paralleli su GPU/ASIC, con un impatto trascurabile (pochi millisecondi) per il login dell'utente legittimo.
- **i.** [**FALSA**]: Nei cifrari a flusso sincroni, la desincronizzazione tra keystream e ciphertext causa il fallimento della decifratura producendo testo incomprensibile (garbled text), ma non compromette affatto la confidenzialità dei dati né consente all'attaccante di risalire al plaintext originale.

1.3 Controllo Accessi e Protocolli di Rete:

- **a.** [**FALSA**]: Il protocollo RADIUS supporta nativamente la funzionalità di RADIUS Proxy (standardizzata in RFC 2865), consentendo a un server locale di inoltrare le richieste `Access-Request` a server RADIUS remoti; tale funzionalità è proprio la base tecnologica dell'infrastruttura globale federata Eduroam.
- **b.** [**VERA**]: PPP (Point-to-Point Protocol, RFC 1661) è progettato per incapsulare e trasportare datagrammi multiprotocollo di livello 3 (come IPv4 o IPv6) su collegamenti punto-punto a livello 2.
- **c.** [**VERA**]: In un'infrastruttura 802.1X/EAP, il protocollo RADIUS trasporta i pacchetti EAP incapsulandoli trasparentemente all'interno degli attributi `EAP-Message` (RFC 3579) senza modificarne il contenuto end-to-end.
- **d.** [**VERA**]: In 802.1X, l'Access Point opera unicamente come *Authenticator* (pass-through L2/L3), delegando completamente l'onere dell'autenticazione delle credenziali dell'utente al server RADIUS backend (*Authentication Server*).
- **e.** [**VERA**]: Nelle specifiche originali di RADIUS (RFC 2865), solo l'attributo `User-Password` viene protetto tramite offuscamento con hash MD5 e shared secret; tutti gli altri attributi (inclusi username e metadati di sessione) viaggiano in chiaro su UDP, risultando insufficienti a garantire la riservatezza (da cui l'adozione di IPsec o RadSec/TLS).
- **f.** [**VERA**]: EAP (Extensible Authentication Protocol, RFC 3748) è un framework middleware universale che disaccoppia i protocolli di livello 2 (Ethernet, Wi-Fi 802.11, PPP) dai metodi specifici di autenticazione (EAP-TLS, EAP-TTLS, PEAP).
- **g.** [**FALSA**]: EAP è stato progettato per essere modulare ed estensibile: per introdurre un nuovo algoritmo o metodo di autenticazione non occorre modificare lo standard di base, ma è sufficiente registrare un nuovo *EAP Type* presso la IANA.
- **h.** [**FALSA**]: PAP invia le credenziali completamente in chiaro sul canale di rete, mentre CHAP usa MD5 (vulnerabile a collisioni e attacchi a dizionario offline); nessuno dei due è considerato un meccanismo di autenticazione forte secondo gli standard attuali.
- **i.** [**FALSA**]: Eduroam richiede obbligatoriamente un'architettura federata gerarchica di proxy RADIUS: quando l'utente si collega a una rete ospite, la richiesta viene instradata dal proxy locale verso il server dell'istituzione di appartenenza (Home IdP) attraverso la federazione.

1.4 Standard di Sicurezza, Sistemi Operativi ed Exploitation:

- **a.** [**VERA**]: Nei Common Criteria (ISO/IEC 15408), un Protection Profile (PP) definisce un insieme standardizzato e indipendente dall'implementazione di requisiti di sicurezza per una specifica tipologia di prodotti, consentendo al fornitore di redigere il proprio Security Target (ST) in modo mirato e conforme.
- **b.** [**FALSA**]: Un disassemblatore è uno strumento di analisi statica che converte il codice macchina in istruzioni assembly senza eseguirlo. Per ispezionare a run-time lo stato dei registri della CPU durante l'esecuzione del processo è indispensabile l'uso di un *Debugger* (es. GDB, WinDbg, x64dbg).

- **c.** [**VERA**]: La Data Execution Prevention (DEP / NX bit / XD bit) impedisce l'esecuzione di codice all'interno di regioni di memoria marcate come non eseguibili (in particolare lo Stack e lo Heap), bloccando i classici buffer overflow che tentano di eseguire shellcode direttamente dallo stack.

- **d.** [**FALSA**]: Rendere il codice incomprensibile è l'obiettivo dell'*offuscamento* (obfuscation). Le tecniche di *anti-tampering*, invece, monitorano l'integrità del binario a runtime (tramite checksum dinamici, rilevamento di breakpoint e controlli anti-debugging) per impedire o rilevare modifiche non autorizzate al codice.

- **e.** [**FALSA**]: Un ISMS (Information Security Management System, ISO/IEC 27001) definisce un sistema di gestione organizzativo e procedurale per la sicurezza delle informazioni a livello aziendale, non è un processo volto a valutare uno specifico prodotto o componente software/hardware (TOE nei Common Criteria).

- **f.** [**VERA**]: La certificazione di sicurezza di terza parte garantisce che un laboratorio accreditato e indipendente abbia valutato e verificato formalmente che il prodotto soddisfi gli specifici requisiti di sicurezza dichiarati.

- **g.** [**FALSA**]: Le tecniche di protezione remota (come l'attestazione TPM remota) non sostituiscono affatto le difese locali contro avversari locali (MATE - Man-At-The-End), e introducono a loro volta dipendenze e vettori di attacco di rete specifici.

- **h.** [**FALSA**]: Il TCSEC (pubblicato dal DoD statunitense nel 1985) è un modello rigido, monolitico e focalizzato primariamente sulla riservatezza e su architetture multi-utente militari; è stato storicamente sostituito dai Common Criteria proprio per via della sua rigidità e inadeguatezza ai sistemi moderni.

- **i.** [**VERA**]: Nei Common Criteria, la certificazione è rigorosamente limitata alla specifica combinazione di hardware, firmware e versione software definita come TOE (Target of Evaluation); non è ammessa alcuna estensione della valutazione ad altre configurazioni per analogia.

1.5 Domanda 5: Ritiro dall'Appello:

- [**FALSA**]: Lo studente che intende completare l'esame e ottenere la verbalizzazione del voto deve indicare "Falso" (selezionare "Vero" comporterebbe la rinuncia e l'annullamento della prova).

1.6 PKI, Crittografia Avanzata e Firme Digitali:

- **a.** [**FALSA**]: Nella ciphersuite `TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256`, le operazioni simmetriche ad alta velocità (AES-128-GCM e SHA-256) vengono comunemente accelerate dalla CPU mediante istruzioni dedicate (come Intel AES-NI e SHA Extensions). Gli HSM sono riservati alla protezione della chiave privata asimmetrica del server (RSA) o alle operazioni di firma, non essendo obbligatori né per AES né per SHA.

- **b.** [**FALSA**]: L'OCSP (Online Certificate Status Protocol, RFC 6960) restituisce lo stato attuale di validità o revoca del certificato al momento dell'interrogazione. Non fornisce prove storiche retroattive sulla validità al momento dell'apposizione della firma, per le quali sono necessarie marche temporali qualificate (TSA) e formati di conservazione a lungo termine (LTV).

- **c.** [**VERA**]: L'algoritmo di Shor consente di risolvere in tempo polinomiale il problema del logaritmo discreto su curve ellittiche (ECDLP), rendendo ECDSA completamente vulnerabile in presenza di computer quantistici crittograficamente rilevanti.

- **d.** [**VERA**]: Se la chiave privata della CA è stata compromessa prima della data di emissione del certificato dell'utente, tale certificato non è affidabile e va scartato, in quanto un attaccante avrebbe potuto forgiarlo illecitamente firmandolo con la chiave compromessa della CA.

- **e.** [**FALSA**]: Gli algoritmi crittografici Post-Quantum (PQC standardizzati dal NIST, basati su reticoli come ML-DSA o su hash come SLH-DSA) sono stati specificamente progettati per resistere agli attacchi quantistici basati sull'algoritmo di Shor e di Grover.

- **f.** [**VERA**]: Un certificato Diffie-Hellman (RFC 3279) include i parametri di dominio pubblici: il numero primo p, il generatore g del gruppo e la chiave pubblica $y = g^x \bmod p$, dove x è la chiave privata dell'intestatario.

- **g.** [**FALSA**]: I documenti firmati in formato PAdES (PDF Advanced Electronic Signatures) contengono il payload del documento in chiaro visualizzabile da qualsiasi lettore PDF convenzionale; solo la verifica crittografica della firma incorporata richiede un software compatibile con le estensioni crittografiche.

- **h.** [**VERA**]: Se un documento firmato contiene macro attive, la firma digitale garantisce solo l'integrità del testo statico e del codice della macro; all'apertura, l'esecuzione del codice della macro può generare dinamicamente contenuti arbitrari differenti da quelli esaminati all'atto della firma.

- **i.** [**VERA**]: Nelle firme parallele, i firmatari firmano indipendentemente il medesimo documento originario; le verifiche crittografiche sono mutuamente indipendenti e possono essere eseguite concorrentemente in parallelo, riducendo sensibilmente il tempo di elaborazione rispetto alle firme sequenziali nidificate a cascata.

1.7 Meccanismi di Autenticazione Avanzati e Credenziali:

- **a.** [**VERA**]: I protocolli Challenge-Response basati su crittografia simmetrica trasmettono sul canale solo sfide casuali (nonce) e risposte calcolate (cifratura o MAC del nonce); la chiave simmetrica non transita mai sulla rete, rendendo il protocollo immune all'intercettazione passiva (sniffing).

- **b.** [**VERA**]: Nel Digital Authentication Model del NIST SP 800-63, il Claimant esegue il protocollo di autenticazione interagendo con il Verifier, il quale certifica l'identità dell'utente al Relying Party (RP) per consentire l'accesso al servizio.

- **c.** [**FALSA**]: Lo Zero-Knowledge Password Proof (es. protocollo SRP, RFC 2945) impiega comunque una password come segreto primario condiviso; consente all'utente di dimostrarne il possesso senza trasmetterla sul canale, ma non costituisce un meccanismo "passwordless".

- **d.** [**VERA**]: Il token FIDO2/WebAuthn implementa un CRA asimmetrico: riceve un challenge crittografico dal server web e genera una risposta firmata con la propria chiave privata hardware; il server backend FIDO verifica la firma mediante la corrispondente chiave pubblica registrata.

- **e.** [**VERA**]: L'aggiunta di fattori biometrici (come l'impronta digitale o il riconoscimento facciale integrati nel dispositivo per sbloccare la chiave privata) aggiunge il fattore "qualcosa che si è" rafforzando significativamente l'autenticazione a più fattori.
- **f.** [**FALSA**]: L'uso di un OTP non è obbligatorio per realizzare la Multi-Factor Authentication: l'MFA può essere implementata mediante token FIDO2 hardware, smart card PKI o notifiche crittografiche push, metodi universalmente considerati più sicuri e resistenti al phishing rispetto agli OTP.
- **g.** [**FALSA**]: In Kerberos v5 (RFC 4120), il Ticket Granting Server invia al client la chiave di sessione effimera $K_{C,S}$ e un Service Ticket cifrato con la chiave a lungo termine del servizio K_S; il client non riceve mai né conosce la chiave segreta a lungo termine K_S del servizio.
- **h.** [**VERA**]: I tratti biometrici di una persona sono permanenti e fisiologicamente immutabili: se un template biometrico viene compromesso o violato, non è possibile revocarlo né sostituirlo, a differenza di quanto avviene per password, certificati o token crittografici.
- **i.** [**VERA**]: Poiché gli utenti tendono a selezionare password derivate dal linguaggio naturale, nomi o schemi frequenti (bassa entropia empirica), a parità di tempo computazionale un attacco a dizionario mirato ha una probabilità di successo enormemente superiore rispetto a una ricerca esaustiva a forza bruta.

Soluzione Parte 2: Compito Scritto

Domanda 1: Reverse Engineering Applicato al Software:

- **Definizione**: Processo di analisi di un sistema software volto a identificarne i componenti, le interrelazioni e a ricostruirne la progettazione e la semantica ad alto livello partendo dal solo artefatto binario compilato.
- **Classificazione dei Tool**:
  - *Disassemblatori*: Convertono il codice macchina binario (`0x55 0x48...`) in istruzioni assembly (es. IDA Pro, Ghidra, radare2, objdump).
  - *Decompilatori*: Ricostruiscono codice sorgente strutturato ad alto livello (C pseudocode) a partire dall'assembly o dalla rappresentazione intermedia IR (es. Hex-Rays, Ghidra Decompiler).
  - *Debugger / Tracer*: Consentono il controllo dinamico dell'esecuzione passo-passo, l'ispezione di registri e memoria e l'impostazione di breakpoint (es. GDB, x64dbg, WinDbg).
  - *Framework di Binary Instrumentation*: Consentono l'inserimento dinamico di sonde a runtime (es. Frida, Intel PIN).
- **Tipi di Analisi**:
  - *Analisi Statica*: Esame del codice senza eseguirlo.
  - *Analisi Dinamica*: Monitoraggio del software durante l'esecuzione in ambiente controllato (sandbox).
  - *Esecuzione Simbolica*: Valutazione dei percorsi del programma trattando gli input come simboli matematici per generare input di exploit (es. angr).

- **Artefatti Ottenuti**: Grafo del Flusso di Controllo (Control Flow Graph - CFG), Grafo delle Chiamate (Call Graph), stringhe estratte, tabella dei simboli/import/export, traccia delle chiamate di sistema (syscall).

Domanda 2: Negoziazione Completa nel TLS Handshake Protocol: Durante l'handshake vengono negoziati:

1. **Versione del Protocollo e Ciphersuite**: Cifratura simmetrica AEAD (confidenzialità), funzione di hash (integrità e PRF), algoritmo di scambio chiavi effimero (PFS).
2. **Autenticazione del Server**: Il server trasmette il proprio certificato X.509 firmato da una CA fidata. Il client verifica la catena fino alla Root CA, la validità temporale e lo stato di revoca (CRL/OCSP).
3. **Scambio Chiavi con Perfect Forward Secrecy (DHE / ECDHE)**: Entrambi i peer generano chiavi effimere casuali su curva ellittica (a, b) e si scambiano i valori pubblici $(a \cdot G, b \cdot G)$. Calcolano il Pre-Master Secret $ab \cdot G$.
4. **Derivazione delle Session Keys**: Tramite PRF basata su HMAC-SHA256 alimentata con Pre-Master Secret e i nonce casuali (R_C, R_S), viene calcolato il Master Secret, da cui si estraggono le chiavi di sessione indipendenti per cifratura client/server e IV.
5. **Verifica di Fine Negoziazione (`Finished`)**: Ciascun peer invia il messaggio cifrato `Finished` contenente il digest verificato di tutti i messaggi precedenti scambiati nell'handshake, garantendo l'integrità della negoziazione contro attacchi di downgrade o manipolazione man-in-the-middle.

Alternative Implementation Note: Strutture Rust per Reverse Engineering e Tooling di Rete

Nello sviluppo di moderni strumenti di analisi di sicurezza o proxy TLS in Rust:

- `std::sync::Arc<parking_lot::RwLock<CFGGraph>>`: Il grafo del flusso di controllo (CFG) generato dal disassembler viene memorizzato in strutture a puntatori atomici condivisibili in parallelo tra thread di analisi statica con latenza minima.
- `crossbeam::channel`: Canali multi-producer multi-consumer per distribuire i blocchi base di codice da analizzare ai thread worker sfruttando appieno i core della CPU.